International Cybersecurity and Digital Forensics Academy (ICDFA)

Course Code: GRC103 –Risk Assessment and Management Techniques

Week 1 Practical Laboratory

Vulnerability Assessment Practical Lab

Environment: Kali Linux 2026.2 (VirtualBox), Metasploitable 2

Tools used: Nmap 7.99, xsltproc, Nikto 2.6.0, Nuclei 3.8.0 (templates v10.5.0), ping, ftp and Telnet clients, Firefox.

Student Name: Mercy Ajayi

Registration Number: C11/26/CGRCE/17219

Date of Submission: October 25, 2026

TABLE OF CONTENTS

1. Introduction **1**
2. Executive summary **2**
What I Found 2
Confirmed Findings and Potential Risks 2
Why It Matters 2
Recommended Actions 3
Assessment Limitations 3
3. Scope, Authorisation and Lab Setup **4**
4. Method **6**
5. Discovery and Service Enumeration **7**
5.1 Host Discovery 7
5.2 Nmap Scan 7
5.3 Service Inventory 9
5.4 Why Open Ports Matter for Compliance 12
6. Vulnerability Identification **13**
6.1 Nikto Web Scan 13
6.2 Manual web inspection and service checks 15
6.3 Nuclei Scans 18
7. Confirmed Observations and Unverified Scanner Results **22**
8. Risk rating method **23**
9. Risk assessment table **24**
10. Limitations **28**

1. Introduction

This report presents a vulnerability assessment of a development server that I assessed as an internal GRC auditor. The target was a Metasploitable 2 virtual machine, which is deliberately vulnerable and commonly used for security training. The assessment was limited to this machine and carried out in an isolated lab with authorisation from my instructor.

The aim was not just to identify technical weaknesses, but also to understand how they could affect the organisation's risk and compliance position. I reviewed the findings, considered their potential impact and recommended actions based on the risks identified. The report includes an executive summary for management and supporting evidence for technical review.

Objectives

- Identify the target and its open ports, services and software versions.
- Use Nmap, Nikto and Nuclei to identify potential vulnerabilities.
- Review the scan results and distinguish findings I confirmed from those that remain unverified.
- Assess the likelihood, impact and inherent risk of each finding.
- Map relevant findings to security controls using CIS Controls v8 and NIST CSF 1.1.
- Present a risk assessment table and an executive summary that management can use to understand the findings and prioritise remediation.

Report Structure

Section 2 presents the executive summary. Sections 3 to 6 cover the lab setup, assessment method, discovery and vulnerability identification. Section 7 explains the confirmed findings and unverified scanner results, while Section 8 describes the risk rating method. Section 9 presents the risk assessment table, and Section 10 covers the limitations.

2. Executive summary

To: IT Management
From: Mercy Ajayi, GRC Audit Team
Date: 20 October 2026
Subject: Security Assessment of Development Server “Metasploitable” (192.168.56.101)

What I Found

I assessed the development server at 192.168.56.101 using Nmap, Nikto and Nuclei. The scans identified 30 open network ports and 21 findings, consisting of 12 High, 7 Medium and 2 Low severity findings. Many of the open ports run outdated or unnecessary services, which could expose the organisation's systems and data to security risks if the server were connected to a production network.

Confirmed Findings and Potential Risks

I manually confirmed six findings. These include anonymous FTP access without a password, an open Telnet service that transmits data without encryption, and a login banner that displays a default username and password. I also confirmed that the PHP information page, phpMyAdmin login page and a directory listing are accessible over the network.

The remaining findings are based on scanner results that I have not manually verified. They include a possible FTP backdoor, a potential remote command execution vulnerability in a build service, and possible default credentials on the database and remote desktop services. I treated these as potential risks rather than confirmed vulnerabilities. I also reviewed the scanner severity ratings and adjusted some that appeared too high based on the evidence available.

Why It Matters

The findings point to a few major security concerns: outdated software, unnecessary services and weak or exposed credentials. These weaknesses could make it easier for an attacker with network access to gain unauthorised access, expose sensitive information or compromise the server.

Recommended Actions

1. **Isolate the server** from shared networks until the identified risks have been addressed.

2. **Disable unnecessary and insecure services**, including Telnet, the r-services on ports 512 to 514, the unexplained shell service on port 1524 and anonymous FTP access.

3. **Change default and weak passwords** and remove exposed credentials from login banners.

4. **Update or replace outdated software**, including Apache, PHP, OpenSSH, Samba, MySQL and vsftpd.

5. **Verify the potential vulnerabilities** through controlled testing and address any that are confirmed.

6. **Use a secure baseline for future development servers**, guided by CIS Controls v8, and carry out regular security reviews.

Assessment Limitations

Nuclei skipped three unresponsive ports and reported errors in 10 templates. Nikto's update check also failed. The findings are based on a single assessment conducted on 20 October 2026, so the results reflect what was observed during that assessment. Further details are provided in Section 10.

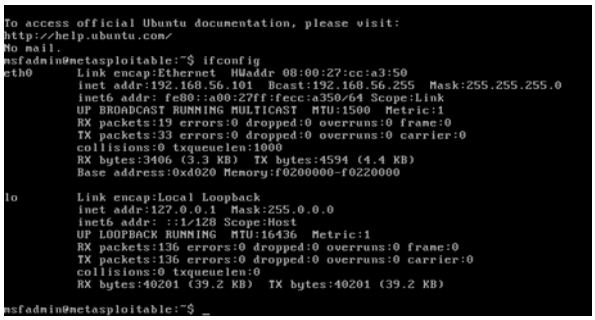
3. Scope, Authorisation and Lab Setup

This assessment was carried out on a Metasploitable 2 virtual machine that I set up for this lab. The target and my Kali Linux testing machine are connected through an isolated VirtualBox host-only network. This keeps the assessment within my lab environment, with no route to the internet from the target machine. No public, institutional or third-party systems were scanned.

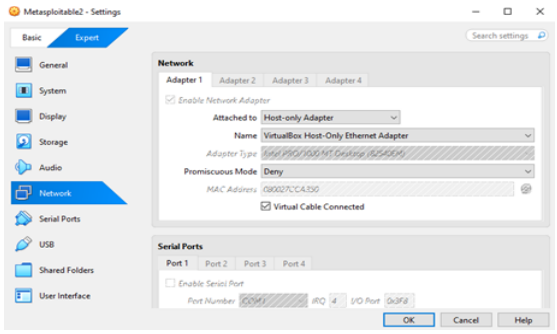
The lab setup is summarised below.

Machine	Role	Network adapter	IP address
Kali Linux 2026.2	Assessor	Adapter 1: NAT for updates only. Adapter 2: Host-only	192.168.56.102 (host only)
Metasploitable 2	Target	Adapter 1: Host only	192.168.56.101

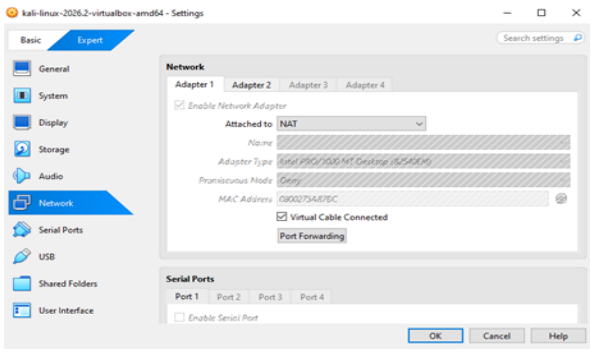
Figure 1 shows the VirtualBox network settings for both machines and the IP address displayed by the target. Figure 2 shows Kali's network interfaces and its host-only IP address.



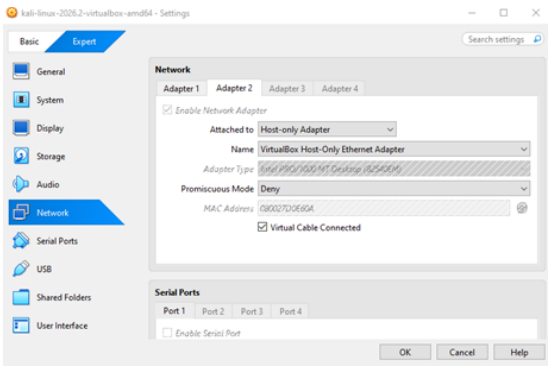
(a) Metasploitable ifconfig: 192.168.56.101



(b) Metasploitable network: host-only adapter



(c) Kali adapter 1: NAT



(d) Kali adapter 2: host-only

Figure 1 shows the lab network configuration.

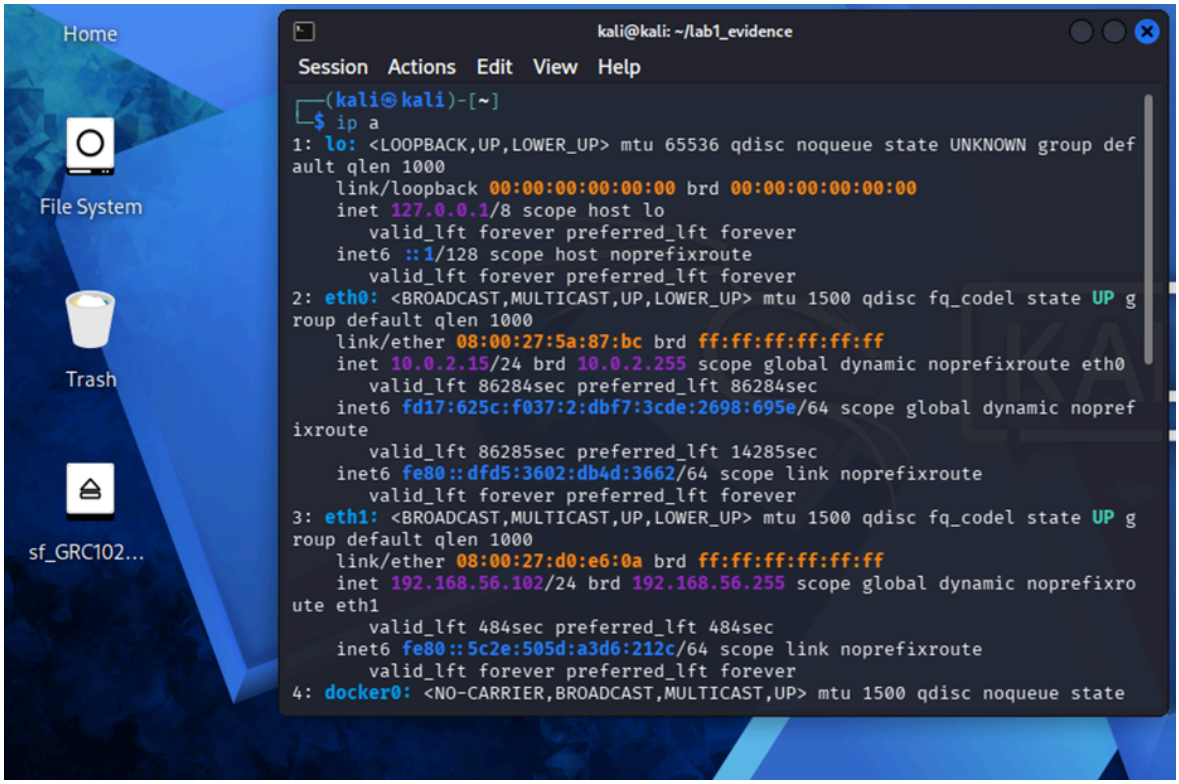


Figure 2 shows Kali "ip a" output: eth1 holds 192.168.56.102 on the host-only network.

4. Method

I followed the three phases outlined in the lab brief: discovery and enumeration, vulnerability identification, and analysis and reporting. I kept the original scan outputs unedited in one evidence folder for reference.

- **Discovery:** I used ping to check whether the target was reachable, followed by a full Nmap scan of all 65,535 TCP ports with version detection, default scripts and OS detection enabled. I also generated an HTML version of the Nmap report.

- **Vulnerability identification:** I ran Nikto against the web server, checked the available web pages manually and ran Nuclei twice, first against web services and then against all services.

- **Manual checks:** I checked what was accessible without attempting to exploit any vulnerability. I logged in to FTP anonymously but disconnected without listing or transferring files. I read the Telnet banner and entered a username at the prompt, but did not enter a password or establish a session. I also opened the phpinfo page, phpMyAdmin login page and directory listing in a browser without logging in.

- **Testing limitations:** I did not run any exploits or attempt any passwords against the services. Findings based only on scanner output are labelled as unverified until they can be confirmed through further testing.

5. Discovery and Service Enumeration

5.1 Host Discovery

I used ping to check whether the target was reachable. All four packets received a response, with 0% packet loss and an average response time of approximately 0.9 ms. This confirmed that the target was active at 192.168.56.101.

Identifying the target and recording its IP address is an important first step in asset inventory. This supports NIST CSF 1.1 ID.AM-1 and CIS Controls v8 Control 1, which focus on identifying and managing an organisation's assets.

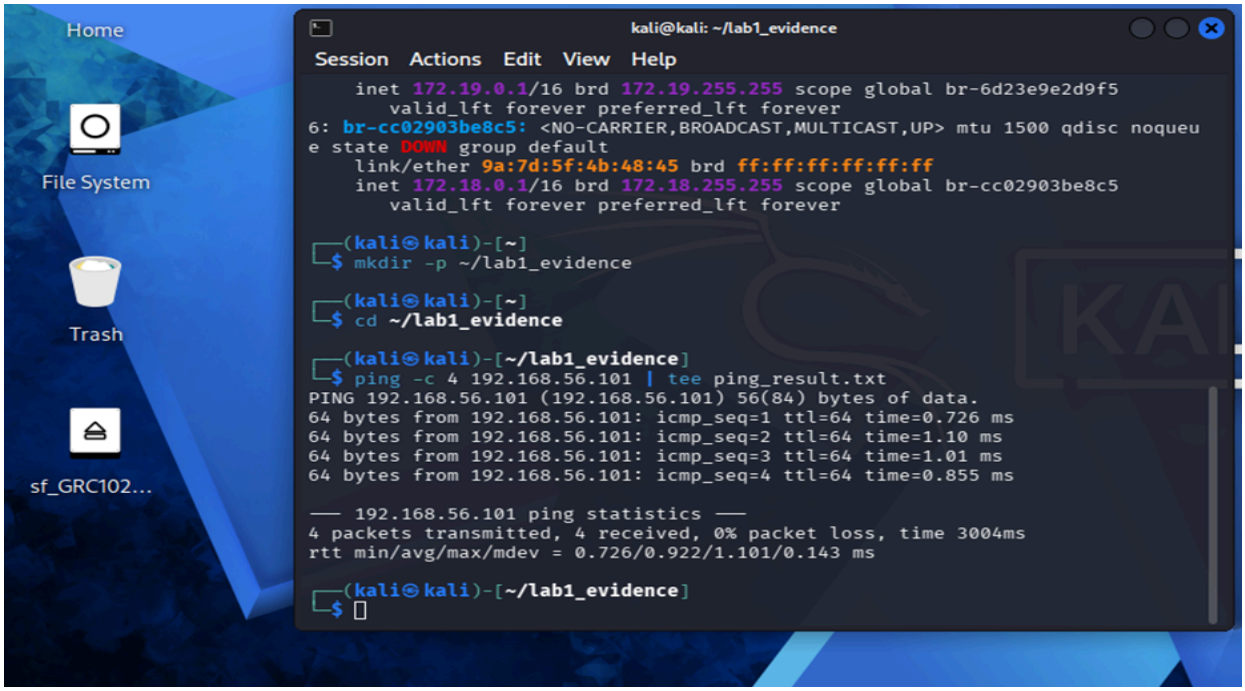


Figure 3 shows Ping to 192.168.56.101: 4 packets sent, 4 received, 0% packet loss.

5.2 Nmap Scan

I ran the following Nmap command to identify open TCP ports, detect service versions, run default scripts and estimate the target's operating system.

Command: **sudo nmap -sV -sC -O -p- -oA initial_scan 192.168.56.101**

The scan took approximately 2.5 minutes and identified 30 open TCP ports. Nmap estimated that the target was running Linux kernel version 2.6.9 to 2.6.33, which is quite old and may indicate that the system is running outdated software.

I saved the raw scan results in **initial_scan.nmap, initial_scan.gnmap** and **initial_scan.xml.** I also used **xsltproc** to generate an HTML report for easier review.



Figure 4 shows the Nmap command and the start of its output.

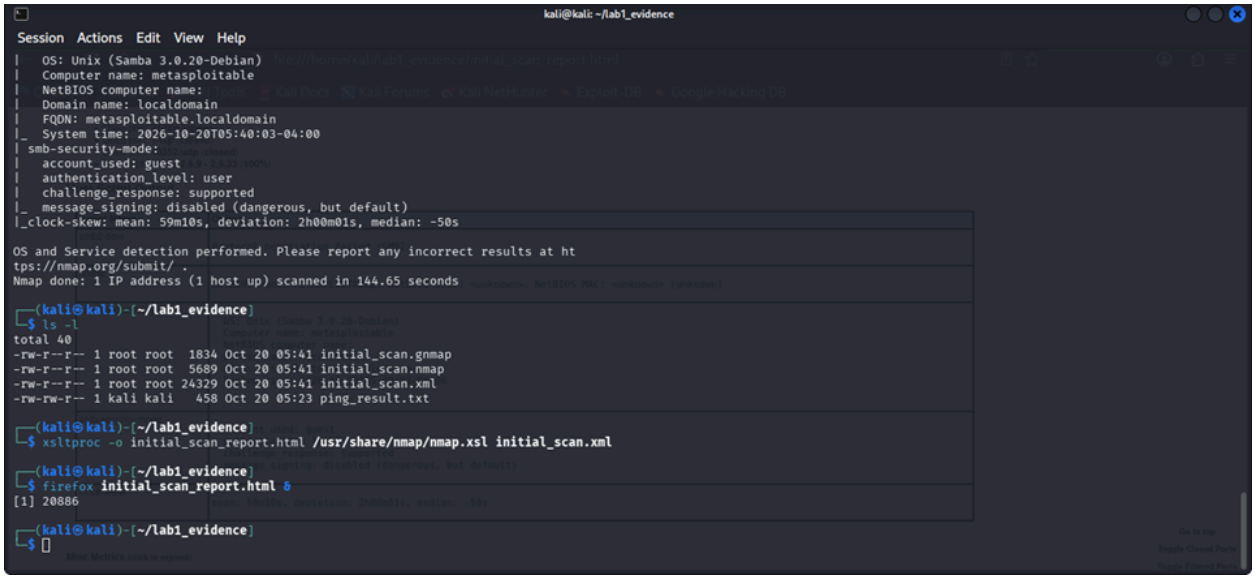


Figure 5. End of the Nmap output ("Nmap done") and the saved output files

5.3 Service inventory

Every open port and the service and version Nmap reported. These are scanner observations, not confirmed vulnerabilities.

Port	Service	Version detected
21	FTP	vsftpd 2.3.4
22	SSH	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23	Telnet	Linux telnetd
25	SMTP	Postfix smtpd
53	DNS	ISC BIND 9.4.2
80	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
111	rpcbind	2 (RPC #100000)
139	NetBIOS-SSN	Samba smbd 3.X - 4.X
445	SMB	Samba smbd 3.0.20-Debian
512	exec	netkit-rsh rexecd
513	login	OpenBSD or Solaris rlogind
514	shell	Netkit rshd
1099	Java RMI	GNU Classpath grmiregistry
1524	bindshell	Metasploitable root shell
2049	NFS	2-4 (RPC #100003)
2121	FTP	ProFTPD 1.3.1
3306	MySQL	MySQL 5.0.51a-3ubuntu5
3632	distccd	distccd v1 (GNU 4.2.4)
5432	PostgreSQL	PostgreSQL DB 8.3.0 - 8.3.7
5900	VNC	VNC (protocol 3.3)
6000	X11	(access denied)
6667	IRC	UnrealIRCd
6697	IRC	UnrealIRCd
8009	AJP	Apache Jserv (protocol 1.3)
8180	HTTP	Apache Tomcat/Coyote JSP engine 1.1
8787	Ruby DRb	Ruby 1.8 DRb RMI

Port	Service	Version detected
34394	mountd	1-3 (RPC #100005)
45402	nlockmgr	1-4 (RPC #100021)
48556	Java RMI	GNU Classpath grmiregistry

Notable Script Output and Observations

- **Port 21:** Anonymous FTP login is allowed, and the control connection does not use encryption.
- **Port 25:** SSLv2 is supported, and the certificate expired in April 2010. The same expired certificate was found on PostgreSQL at port 5432.
- **Port 445:** SMB message signing is disabled.
- **Port 5900:** VNC uses password authentication only.
- **Port 80:** The page title is “Metasploitable2 - Linux”, and the Apache version is very old.
- **Ports 6667 and 6697:** UnrealIRCd was detected, but Nmap did not report a version number.

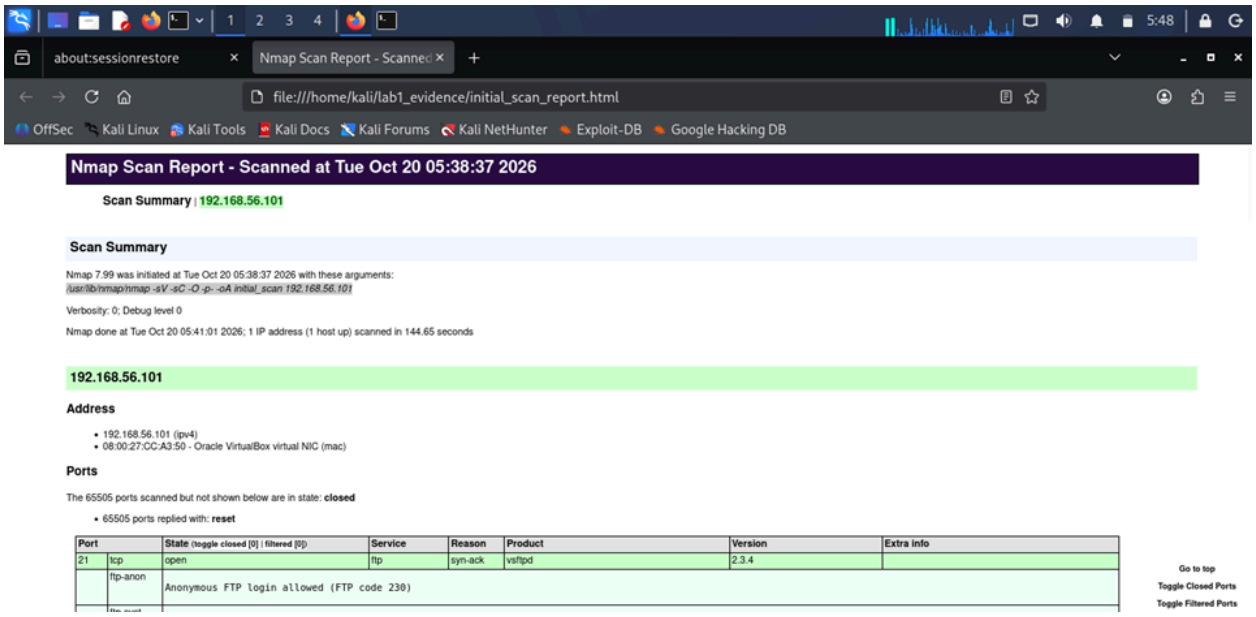


Figure 6 shows Nmap HTML report: scan summary for 192.168.56.101

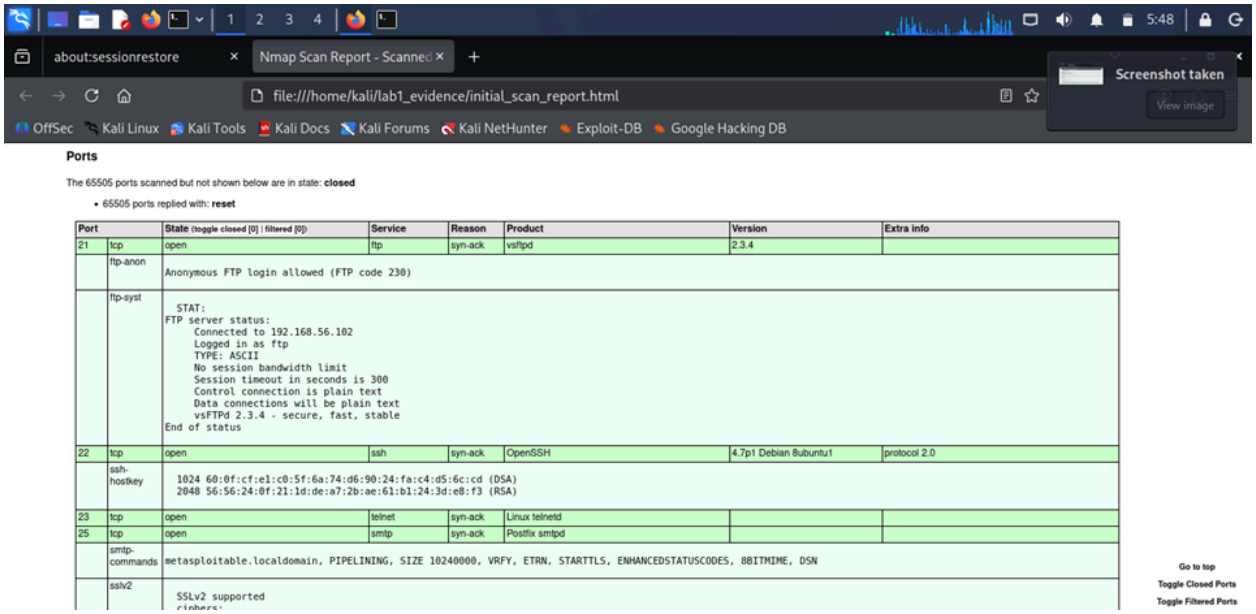


Figure 7 shows Nmap HTML report: open ports and service versions.

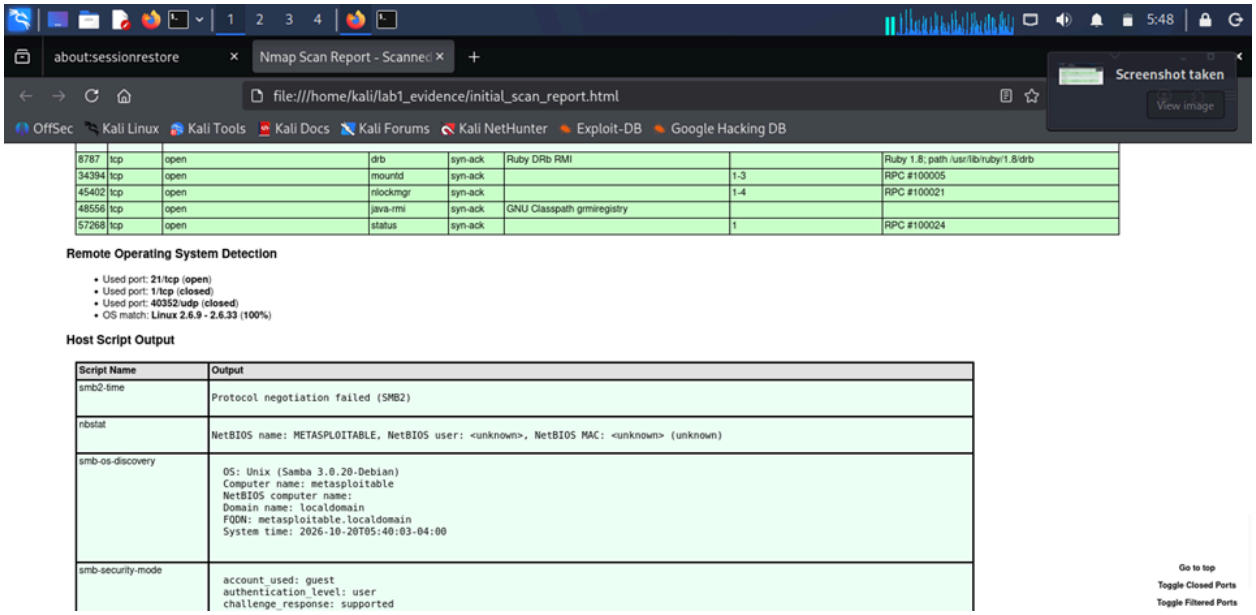


Figure 8 shows Nmap HTML report: OS detection and host script output.

5.4 Why Open Ports Matter for Compliance

Open ports allow network services to be accessed, which increases the server's attack surface. The scan identified 30 open ports, including services that may not be necessary for a development server. These include Telnet on port 23, rsh and rlogin on ports 512 to 514, a root shell listener on port 1524 and anonymous FTP on port 21.

From a GRC perspective, organisations need to know which services are running and ensure that only necessary ones are accessible. CIS Controls v8 Safeguard 4.8 recommends disabling or removing unnecessary services, while NIST CSF 1.1 PR.IP-1 focuses on maintaining secure configuration baselines. Leaving unnecessary services exposed makes it harder to show that these security expectations are being met.

Services such as Telnet and FTP also create additional risks because they can transmit information without encryption. This could expose credentials and other sensitive information, which relates to the protection of data under NIST CSF 1.1 PR.DS-2.

Framework version note: The lab brief refers to CIS Control 9, which applies to version 7 of the framework. This report uses CIS Controls v8, where Safeguard 4.8 addresses the disabling or removal of unnecessary services.

6. Vulnerability Identification

6.1 Nikto Web Scan

I used Nikto to check the target's web server for potential security issues.

Command: `nikto -h http://192.168.56.101 -o nikto_scan.txt`

The scan sent 8,242 requests over 372 seconds and reported 30 items, with 16 errors recorded. The update check failed with a 403 error. Nikto initially saved the output as **`nikto_scan.txt.txt`**, so I renamed the file to **`nikto_scan.txt`.**

Main observations:

- **Outdated software:** Apache 2.2.8 and PHP 5.2.4 were reported. The PHP version is also exposed in a response header.
- **Exposed files and directories:** The scan identified **`phpinfo.php`**, phpMyAdmin and its ChangeLog and README files. It also found browsable directories, including **`/icons/`**, **`/doc/`** and **`/test/`**.
- **HTTP methods and security headers:** The HTTP TRACE method is enabled, and several security headers are missing, including Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy.
- **File discovery:** Apache's **`mod_negotiation`** feature has MultiViews enabled, which may make it easier to discover files by guessing their names.

These results identify areas that need further review, particularly outdated software, exposed files and directories, and missing security protections.

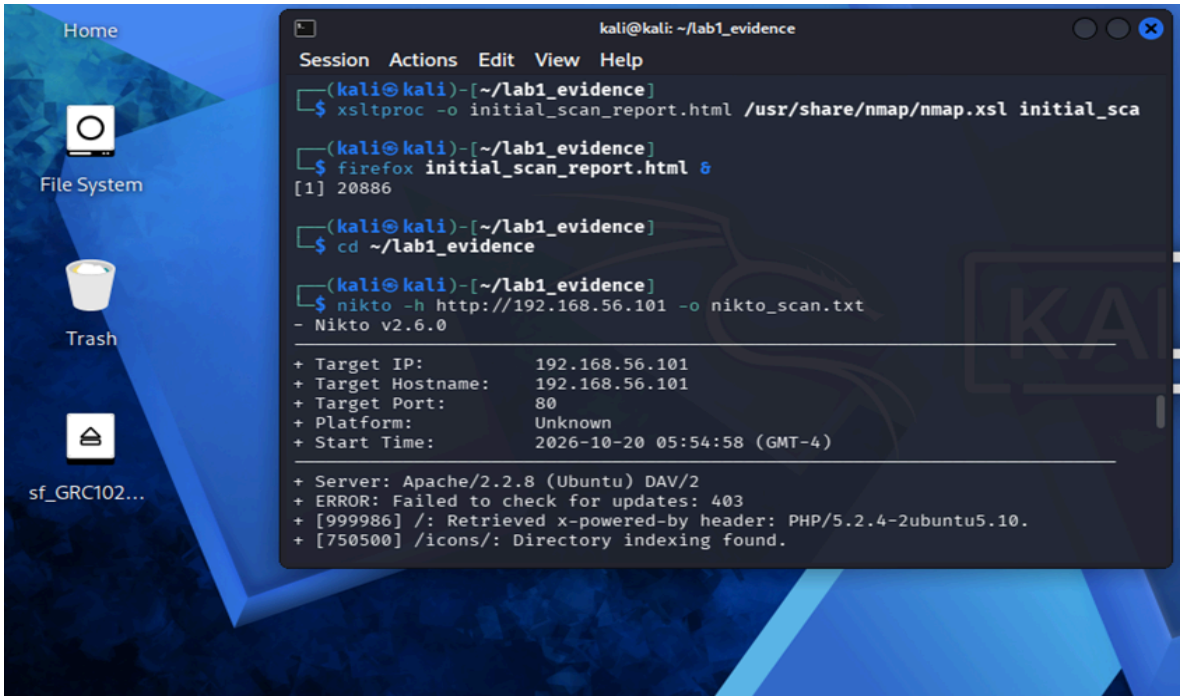


Figure 9 shows Nikto: command, target details and first findings.

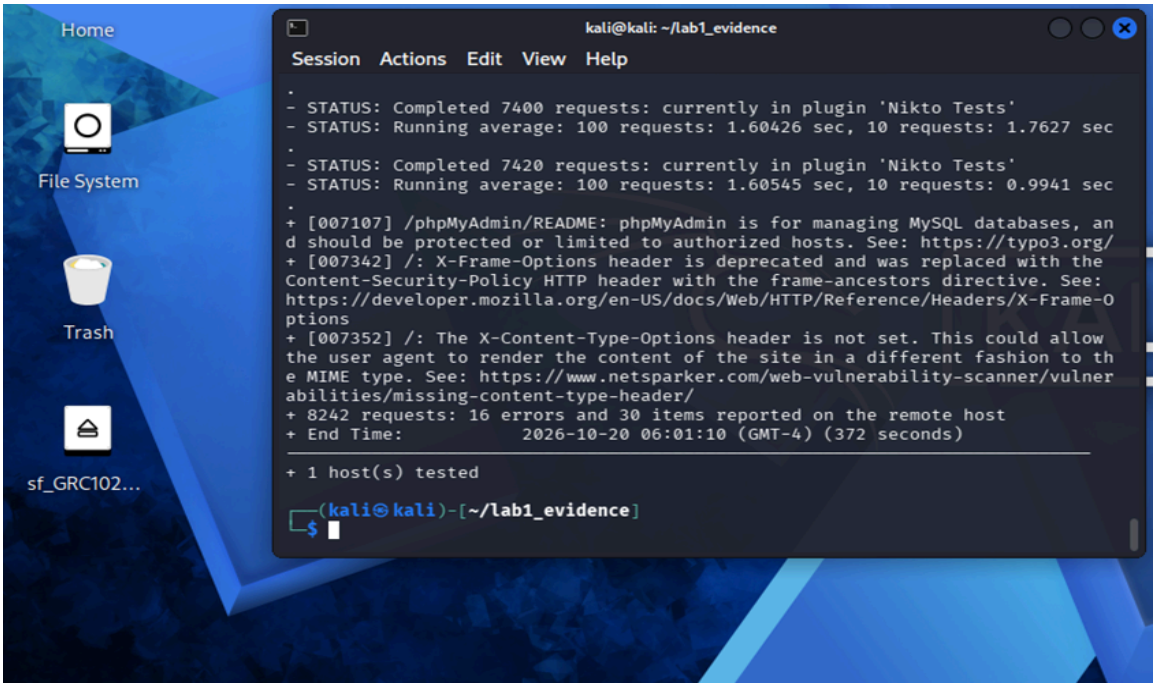


Figure 10 shows Nikto: end of the scan (8,242 requests, 16 errors, 30 items; 1 host tested).

6.2 Manual web inspection and service checks

I checked a handful of scanner findings by hand so they can be reported as confirmed. Figure 11 shows the Metasploitable2 landing page, which links to several test web applications.

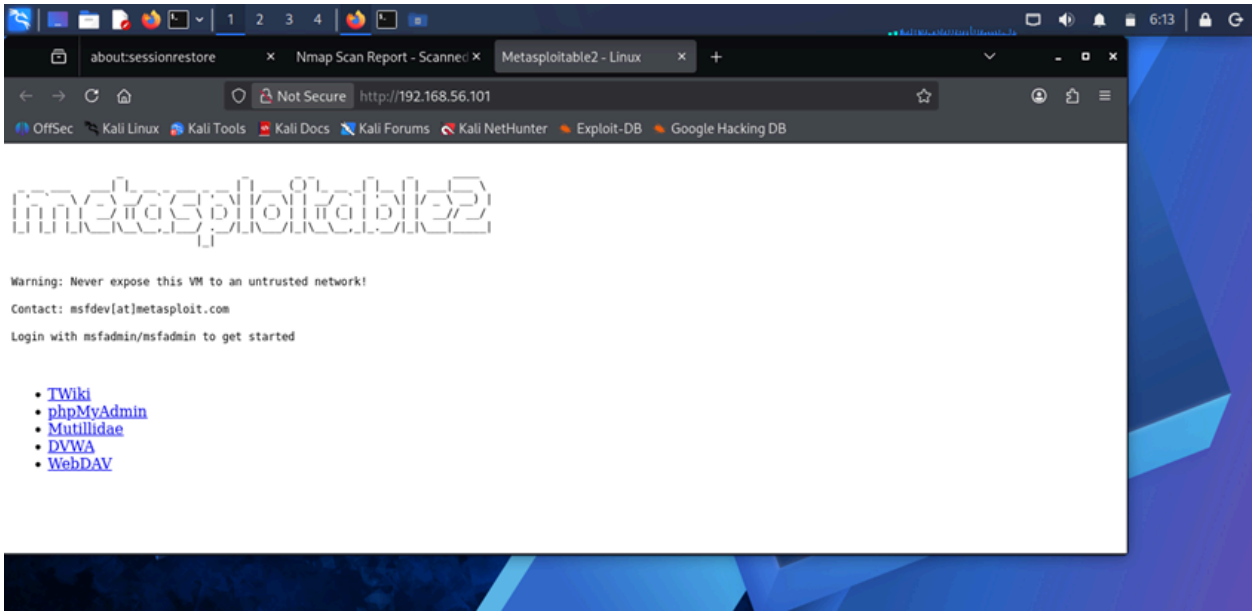


Figure 11 shows the home page of the web server at http://192.168.56.101/.

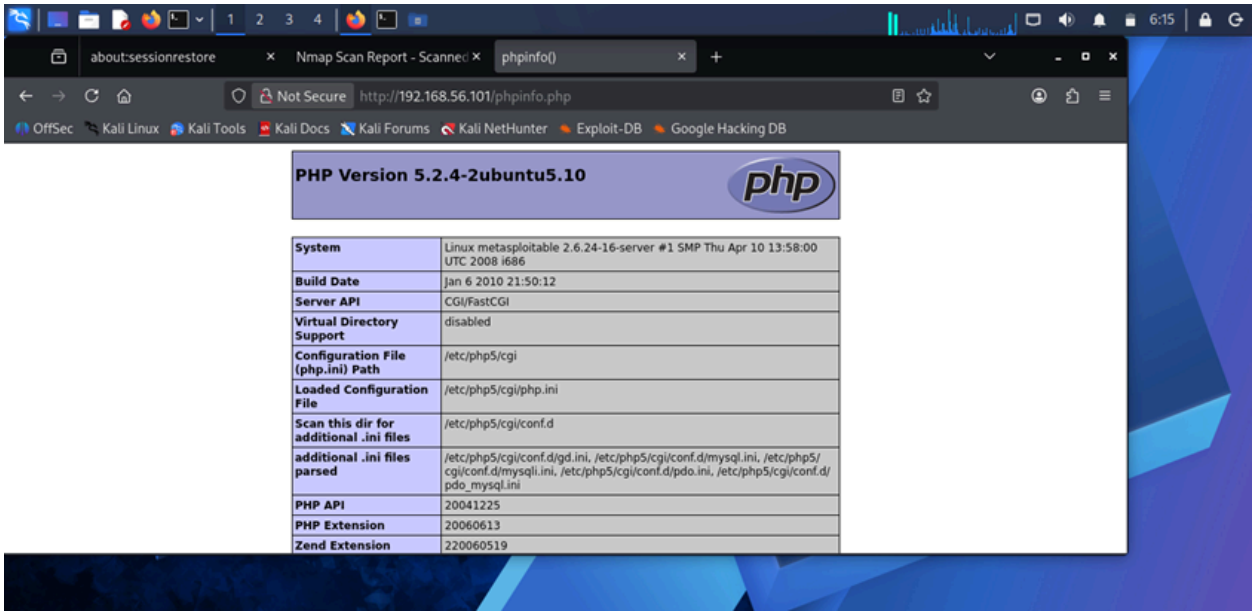


Figure 12 shows that phpinfo.php is publicly readable and shows PHP version 5.2.4

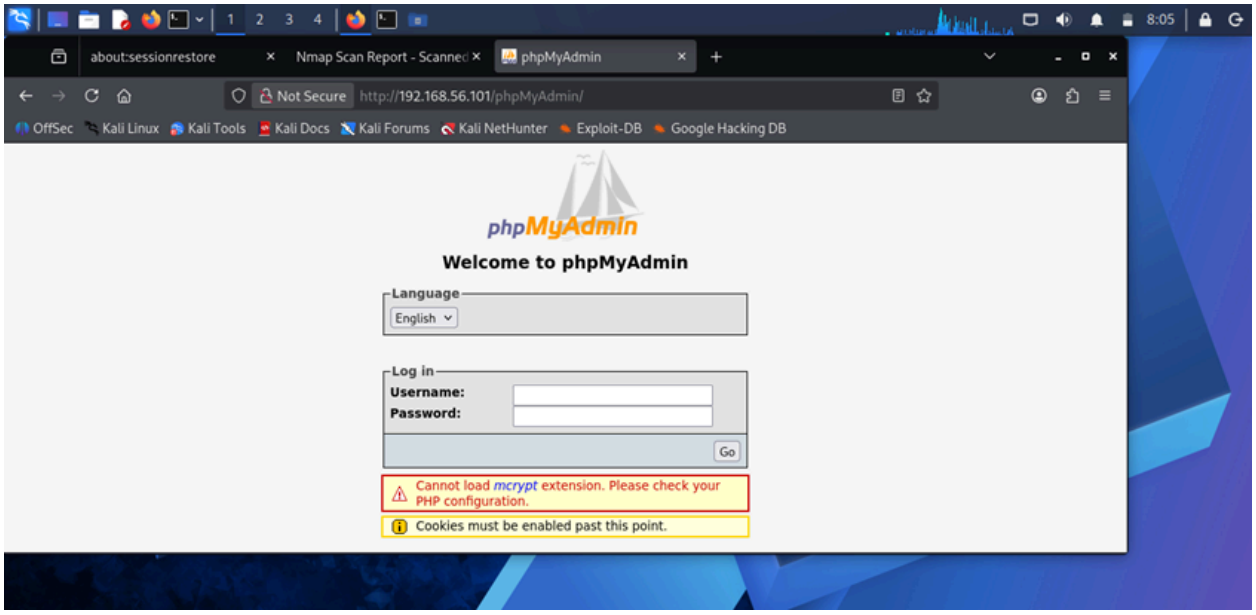


Figure 13 shows the phpMyAdmin login page reachable at /phpMyAdmin/ (not logged in). The page also shows an mcrypt configuration error.

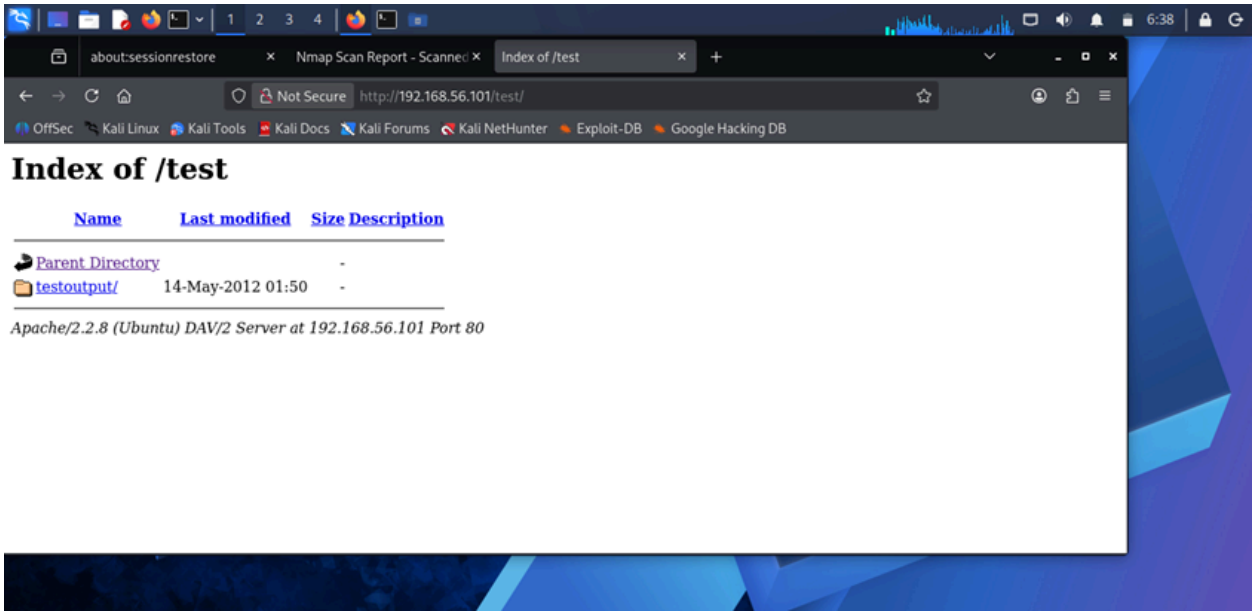


Figure 14 shows Directory listing enabled at /test/.

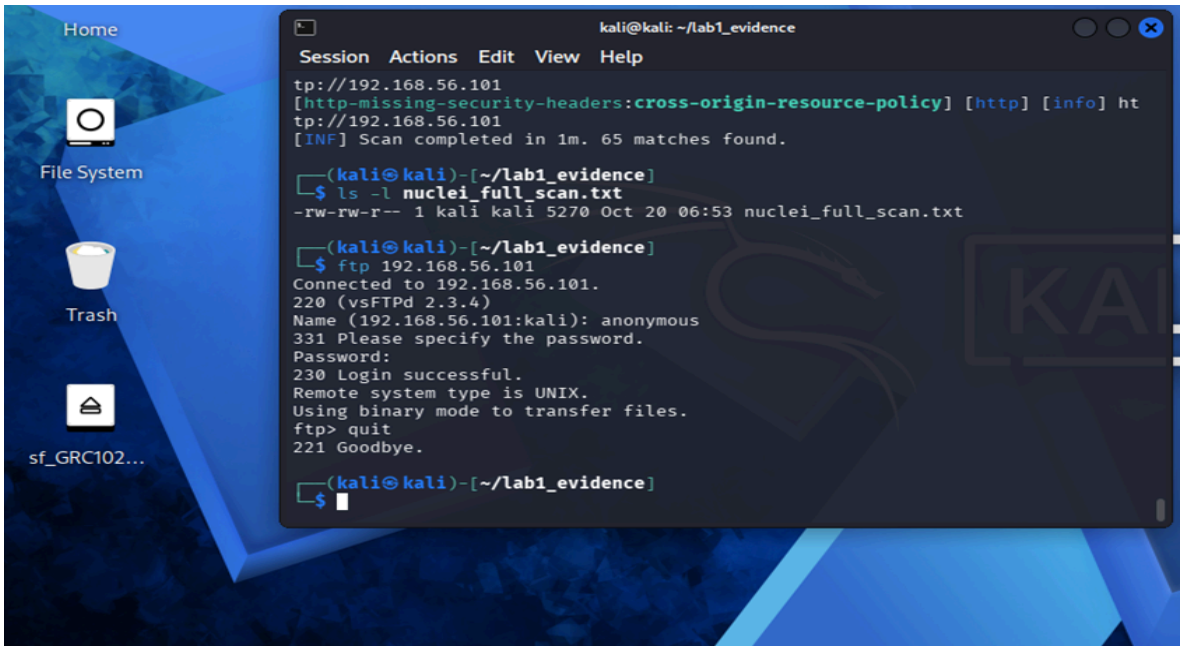


Figure 15 shows Anonymous FTP login accepted (230 Login successful) on vsFTPd 2.3.4. Disconnected immediately after.

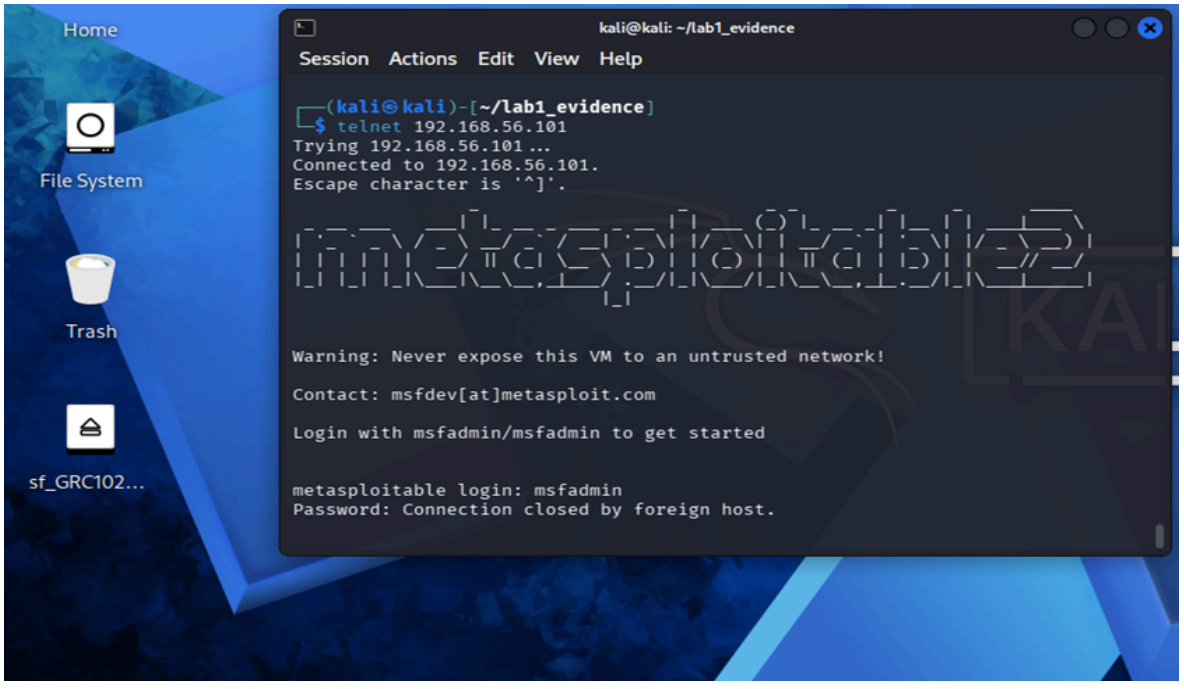


Figure 16 shows Telnet is reachable; the login banner discloses the default username and password. No password was entered.

6.3 Nuclei Scans

I ran two Nuclei scans using 11,135 signed templates from version 10.5.0 to identify potential vulnerabilities on the target.

- **Web scan: `nuclei -u http://192.168.56.101 -o nuclei_web_scan.txt`**
  This scan reported 71 matches and took approximately 2 minutes.
- **Full scan: `nuclei -target 192.168.56.101 -o nuclei_full_scan.txt`**
  This scan reported 65 matches and took approximately 1 minute.

The results from both scans overlap considerably. The web scan also checked some non-web services, which helps explain the overlap. I did not treat every match as a confirmed vulnerability because some results were based only on software version detection. Nuclei's severity labels are the scanner's own ratings and are separate from the risk ratings assigned in this report.

Errors and limitations: Both scans reported runtime errors in 10 templates. Nuclei also indicated that the installed version, 3.8.0, was outdated. During the web scan, ports 9780, 4040 and 5814 were skipped because they were unresponsive. During the full scan, ports 4040 and 5814 were skipped for the same reason. Nuclei reported these ports as closed or filtered.

These limitations mean that the scan results may not provide a complete picture of the target's vulnerabilities. Findings based only on version matches or scanner output remain unverified until further testing confirms them.

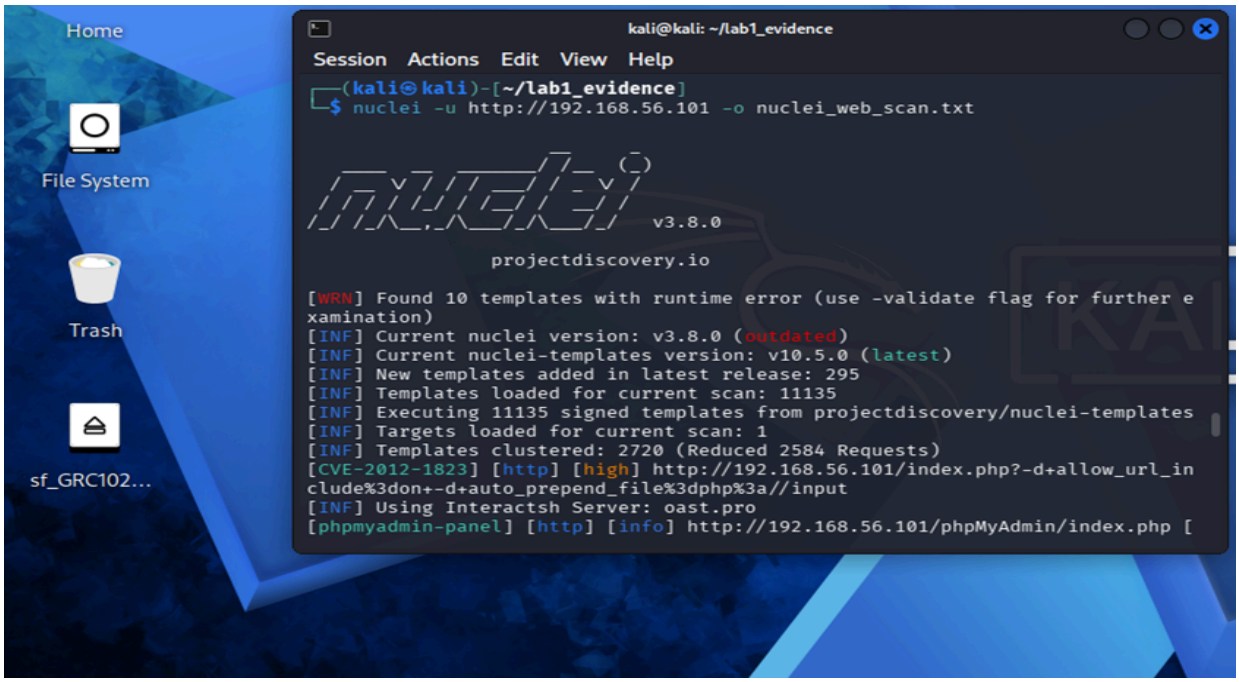


Figure 17 shows the Nuclei web scan: command, warning about 10 templates with runtime errors, and first findings.

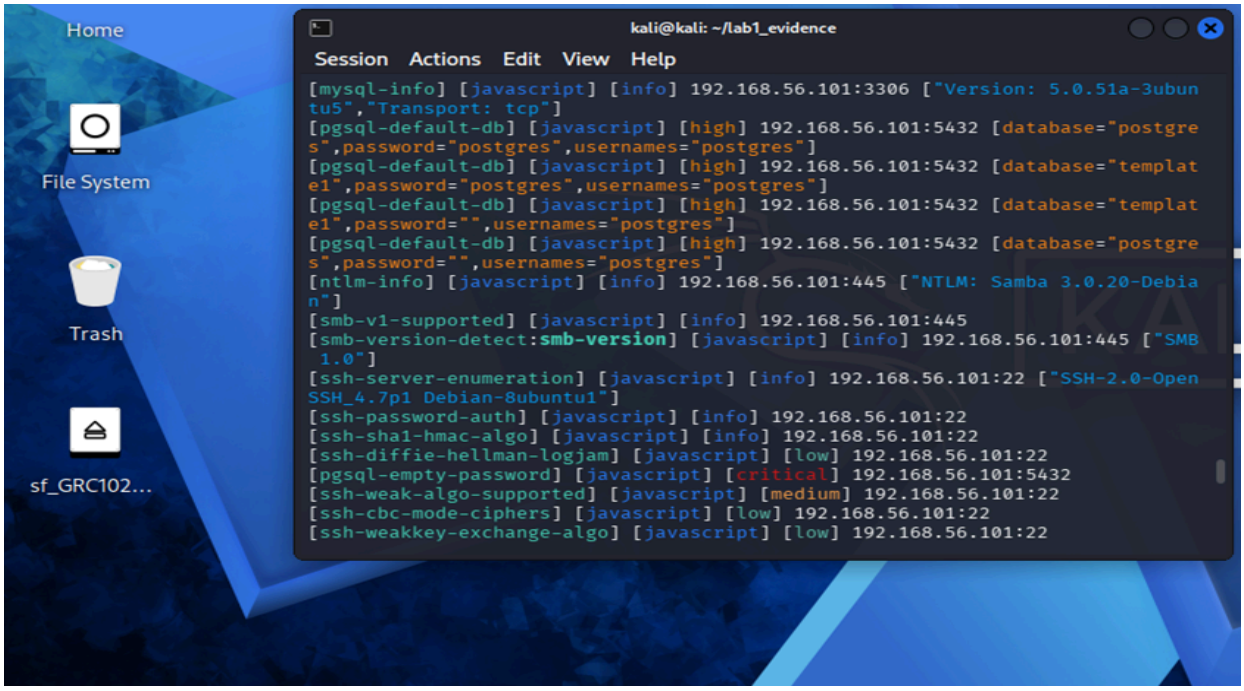


Figure 18 shows the Nuclei web scan: findings on the database, SMB and SSH services.

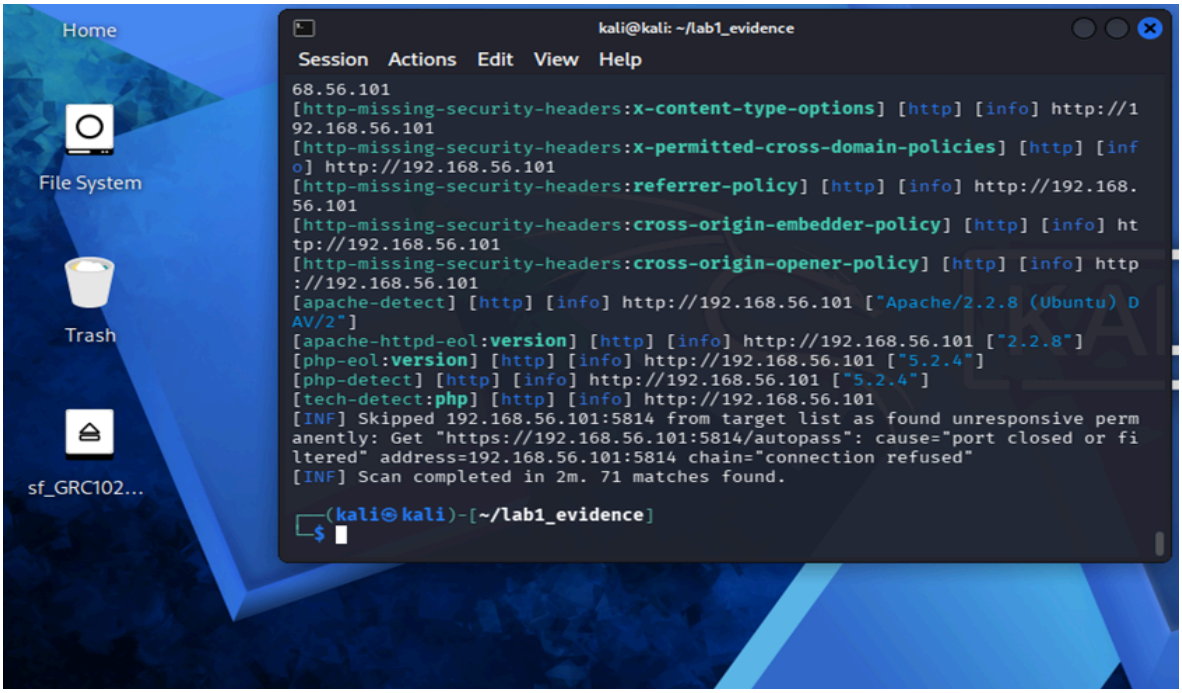


Figure 19 shows Nuclei web scan: skipped unresponsive port and completion (71 matches).

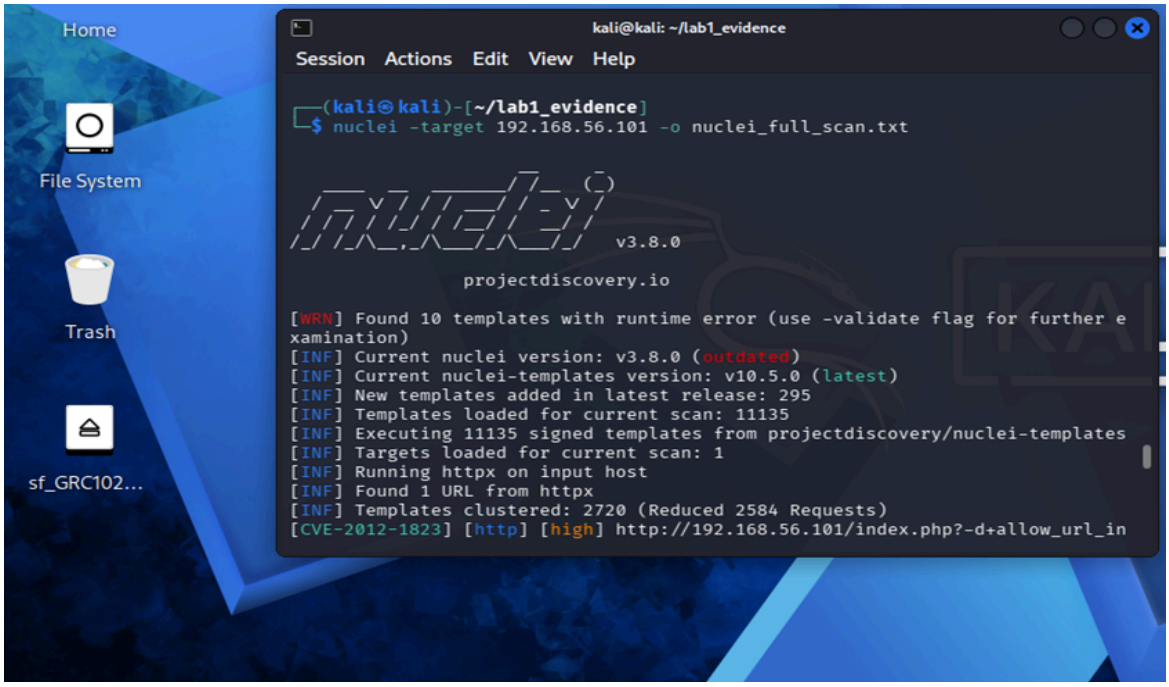


Figure 20 shows Nuclei full scan: command, warnings and first findings.

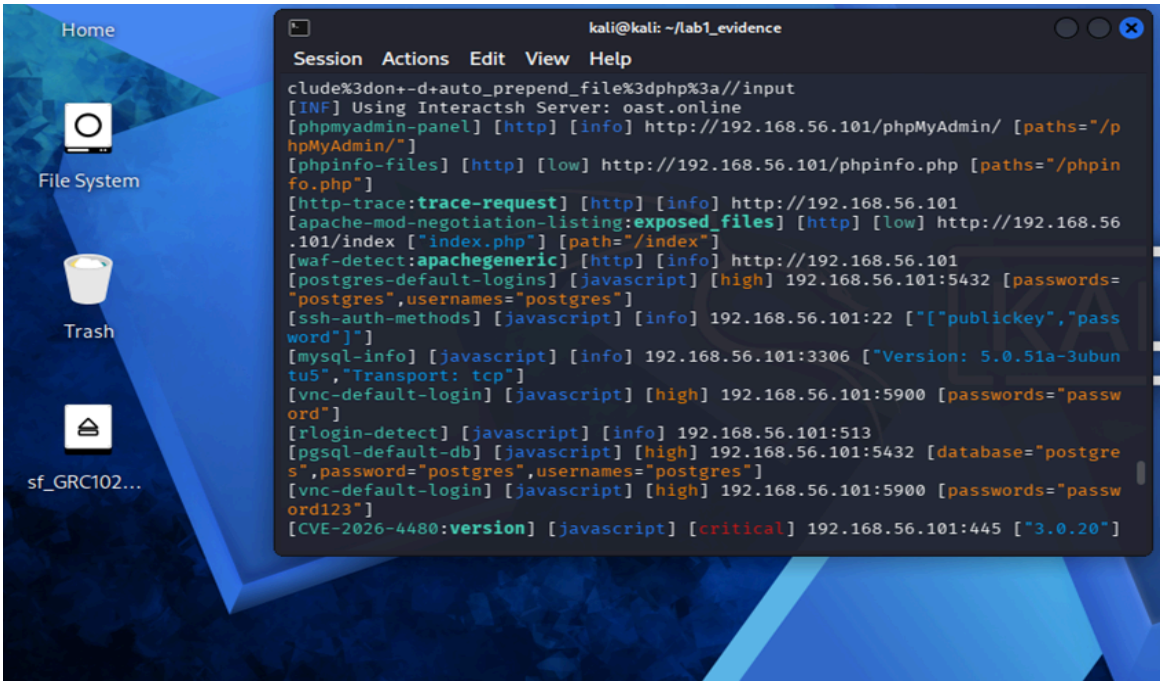


Figure 21 shows Nuclei full scan: findings.

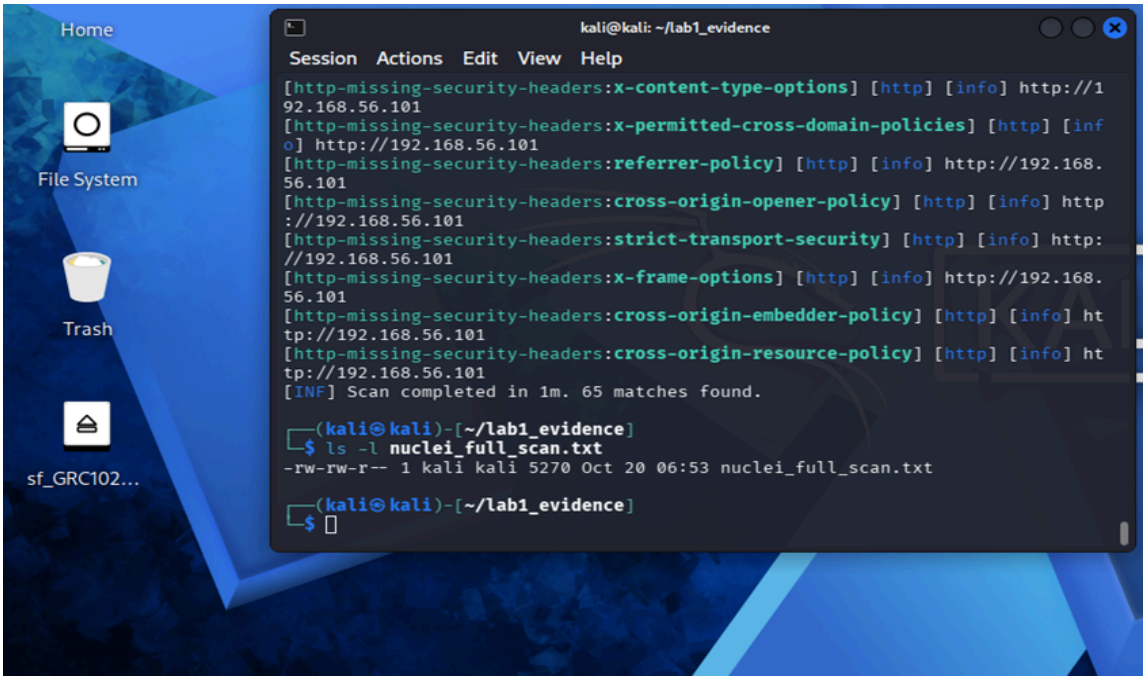


Figure 22 shows Nuclei full scan: completion (65 matches) and the saved output file.

7. Confirmed Observations and Unverified Scanner Results

Scanner results do not automatically mean that a vulnerability exists. I grouped the findings according to the evidence available, and the Status column in the risk table follows the same classification.

Group	Findings	Basis
Confirmed by manual check	Anonymous FTP login (1); Telnet reachable with default credentials shown in the banner (2, 3); phpinfo.php exposed (4); phpMyAdmin login page reachable (5); directory listing on /test/ (6)	I saw each one myself (Figures 15 and 16, and the web pages above).
Observed directly by Nmap	Outdated software versions (7); shell service on port 1524 (8); r-services (9); SMB signing disabled (10); SSLv2 and expired certificates (11); NFS and RPC exposed (12)	Nmap reported these services and settings. I did not test how they behave.
Unverified scanner results	vsFTPd backdoor (13); distccd (14); PostgreSQL default password (15); VNC weak password (16); PHP-CGI injection (17); AJP “Ghostcat” (18); Samba CVE-2026-4480 (19); HTTP TRACE (20); missing headers (21)	Reported by Nuclei and/or Nikto only. None were exploited or tested by hand, so they are labelled potential.

Notes on selected scanner results

Nuclei reported seven possible matching passwords for the FTP user ftp. Since anonymous FTP access accepts a password that is not actually used for authentication, these matches do not establish that seven valid passwords exist. I therefore considered the confirmed anonymous access separately from the unverified password findings.

Nuclei also reported two possible passwords for VNC. Since I did not test either password, the finding remains unverified.

For AJP Ghostcat, Nuclei assigned a Critical severity rating. However, the affected Tomcat versions documented for this vulnerability start from version 7.x, while the server runs Tomcat 5.5. I rated this finding Medium because the version information did not clearly support the scanner's rating. It remains a potential false positive until further testing confirms whether the vulnerability applies.

8. Risk rating method

Each finding is rated for likelihood (how easy it is to exploit) and impact (what happens if it is exploited), each scored 1 to 3. The inherent risk is the product of the two scores. “Inherent” means the risk before any fixes, with no existing controls taken into account.

Score	Likelihood	Impact
High (3)	Reachable over the network and needs no skill or no login, for example, anonymous access or a default password	Full system compromise or loss of sensitive data
Medium (2)	Reachable, but needs some skill, tools or conditions	Partial data exposure or limited access
Low (1)	Hard to exploit, or limited to information disclosure	Minor information disclosure

Inherent risk	Score (L x I)	Meaning
High (H)	6 to 9	Easy to exploit and leads to serious compromise or loss of data
Medium (M)	3 to 4	Needs some conditions, or leads to partial exposure
Low (L)	1 to 2	Information disclosure or a hardening gap with low impact

Controls are listed as relevant benchmarks from CIS Controls v8 and NIST CSF 1.1. A control gap is only stated where the evidence supports it, and the Status column says what that evidence is. Where I could not confirm exposure, the rating is provisional.

9. Risk assessment table

Findings are ordered with the hand-confirmed items first. Figure numbers in the Status column point to the evidence in sections 5 and 6. Summary: 12 High, 7 Medium, 2 Low (21 findings).

S/N	Finding	Affected service	CVE / reference	Likelihood	Impact	Inherent risk	Relevant controls (CIS v8 / NIST CSF 1.1)	Business impact	Remediation	Status and evidence
1	**Anonymous FTP login allowed**	FTP, 21 (vsftpd 2.3.4)	N/A	High (3): no credentials needed	Medium (2): unauthenticated file access; contents not reviewed	**High (6)**	CIS 4.8, 6.8 / PR.AC-4, PR.PT-3	Anyone on the network can read, and possibly write, files without logging in.	Disable anonymous access, or retire FTP and use SFTP.	Confirmed by hand (Fig. 15). Nuclei's "weak credentials" results for user ftp (seven different passwords) are explained by anonymous access; they are not separate weak passwords.
2	**Telnet service exposed (plain-text remote login)**	Telnet, 23	CWE-319	High (3): reachable, no skill needed	High (3): credentials can be captured on the network, giving remote access	**High (9)**	CIS 3.10, 4.8 / PR.DS-2, PR.PT-3	Stolen admin credentials could lead to full takeover of the server.	Disable Telnet and use SSH only.	Service reachability confirmed (Fig. 16). The plain-text risk is a known property of the protocol; traffic was not captured.
3	**Login banner discloses default credentials**	Telnet, 23	CWE-200	High (3): shown to anyone who connects	High (3): reveals a username and password pair	**High (9)**	CIS 5.2, 4.1 / PR.AC-1, PR.IP-1	Unauthorised access without any hacking skill.	Remove credentials from banners and change default passwords.	Banner disclosure confirmed (Fig. 16). Whether the credentials work was not tested.
4	**phpinfo.php page publicly accessible**	HTTP, 80 (Apache 2.2.8, PHP 5.2.4)	CWE-200	High (3): open to anyone, no login	Low (1): reveals configuration but gives no direct access	**Medium (3)**	CIS 4.1, 16.7 / PR.IP-1, PR.DS-5	Gives an attacker exact PHP version, paths and settings, making targeted attacks easier.	Delete the file; do not expose phpinfo() on live systems.	Confirmed by hand (Fig. 12); also flagged by Nikto and Nuclei.
5	**phpMyAdmin database admin page reachable**	HTTP, 80	N/A	Medium (2): login page open to the network;	High (3): database admin tool; a successf	**High (6)**	CIS 4.1, 4.8 / PR.AC-3, PR.PT-3	A compromise could lead to loss or tampering	Restrict by IP or remove it, enforce strong passwords, update it.	Page reachable, confirmed (Fig. 13); login not attempted. The page also shows a PHP error ("Cannot

				credentials not tested	ul login could expose or alter data			of database contents.		load mcrypt extension”).
6	**Directory listing enabled (/test/)**	HTTP, 80	CWE-548	High (3): open to anyone	Low (1): only a folder named testoutput/ was seen; contents not reviewed	**Medium (3)**	CIS 4.1, 16.7 / PR.IP-1, PR.DS-5	Visitors can browse server folders and may find files not meant to be public.	Turn off directory indexing (Options -Indexes).	Confirmed for /test/ (Fig. 14). /icons/ and /doc/ are Nikto-only.
7	**Outdated, end-of-life software**	Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, Samba 3.0.20, MySQL 5.0.51a, vsftpd 2.3.4	No single CVE (Nuclei apache-httpd-eol and php-eol also flagged)	Medium (2): old versions have many public flaws, but no specific one was verified	High (3): unpatched flaws can lead to system compromise	**High (6)**	CIS 2.2, 7.4 / ID.RA-1, PR.IP-12	Known weaknesses stay open because vendors no longer patch these versions.	Upgrade or replace the software and set up patch management.	Versions observed by Nmap. Specific vulnerabilities unverified; distributions sometimes patch old versions without changing the version number, so a version match alone does not prove exposure.
8	**Remote shell service listening**	Port 1524, identified by Nmap as “bindshell” (“Metasploitable root shell”)	N/A	High (3): open port; no skill needed if it works as labelled	High (3): a root shell would mean full control	**High (9)**	CIS 4.4, 4.8 / PR.PT-3, PR.AC-3	An attacker could take complete control of the server.	Close the port, find and remove the process, firewall the server.	Nmap service identification only. Not connected to, so root access is unverified.
9	**r-services exposed (rexec, rlogin, rsh)**	Ports 512, 513, 514	N/A (Nuclei rlogin-detect also flagged 513)	Medium (2): exploitation depends on trust settings that were not tested	High (3): remote command execution over plain text	**High (6)**	CIS 3.10, 4.8 / PR.DS-2, PR.PT-3	Weak, plain-text remote access that can lead to unauthorised commands.	Disable these services and use SSH.	Ports observed open by Nmap. Authentication behaviour not tested.
10	**SMB message signing disabled; SMBv1 supported**	SMB, 445 (Samba 3.0.20)	N/A (Nuclei smb-v1-supported also flagged)	Medium (2): attacker needs a position on the network	Medium (2): file-sharing traffic could be tampered with or relayed	**Medium (4)**	CIS 4.1, 4.8 / PR.DS-2, PR.IP-1	Weak protection for internal file-sharing traffic.	Require SMB signing, disable SMBv1, upgrade Samba.	Observed by Nmap. Interference not tested.

11	**Obsolete SSLv2 and expired certificates**	SMTP, 25 (expired certificate also seen on PostgreSQL, 5432)	N/A	Medium (2): needs a network position to exploit weak encryption	Medium (2): mail or database traffic could be exposed	**Medium (4)**	CIS 3.10, 4.1 / PR.DS-2, PR.IP-1	Traffic that should be encrypted is weakly protected; an expired certificate points to poor certificate management.	Disable SSLv2, use TLS 1.2 or higher, replace the certificates.	Observed by Nmap (SSLv2 ciphers listed; certificate validity ended in 2010). Not tested further.
12	**NFS and RPC services exposed**	NFS, 2049; rpcbind, 111	N/A (Nuclei nfs-v3-exposed also flagged)	Medium (2): reachable, but share permissions were not checked	Medium (2): provisional; shared folders and who can read them are unknown	**Medium (4)**	CIS 3.3, 4.8 / PR.AC-3, PR.PT-3	If shares are open, files could be read or changed from other machines.	Restrict exports to named hosts, firewall the services, or disable NFS.	Services observed. Exports not enumerated, so the rating is provisional.
13	**vsFTPd 2.3.4 backdoor (potential)**	FTP, 21 / port 6200	CVE-2011-2523	High (3): if present, needs no credentials	High (3): remote command shell	**High (9)**	CIS 2.2, 7.4 / PR.IP-12, DE.CM-8	Full compromise of the server by an unauthenticated attacker.	Replace vsftpd with a current, trusted package; block port 6200.	UNVERIFIED. Nuclei flagged it and the version is confirmed as 2.3.4, but the backdoor was not reproduced by hand.
14	**distccd remote command execution (potential)**	distccd, 3632	CVE-2004-2687	High (3): service open to the network	High (3): runs commands on the server	**High (9)**	CIS 4.8, 7.4 / PR.PT-3, PR.AC-3	An attacker could run commands as a service user and move further.	Disable distccd or restrict it to trusted build hosts.	UNVERIFIED. Nmap confirmed the service is open; Nuclei flagged the CVE; not tested.
15	**PostgreSQL default or empty password (potential)**	PostgreSQL, 5432	N/A (Nuclei pgsql-empty-password, postgres-default-logins)	High (3): default credentials need no skill	High (3): database read and write access	**High (9)**	CIS 4.7, 5.2 / PR.AC-1	Exposure or tampering of database contents.	Set strong, unique passwords and restrict access by IP.	UNVERIFIED. Reported by Nuclei only; no login was attempted.
16	**VNC weak or default password (potential)**	VNC, 5900	N/A (Nuclei vnc-default-login)	High (3): weak passwords need no skill	High (3): remote desktop control	**High (9)**	CIS 5.2, 4.7 / PR.AC-1, PR.AC-3	An attacker could view and control the server's desktop.	Set a strong password, restrict by IP, tunnel over SSH or disable.	UNVERIFIED. Nmap confirmed VNC is open with password authentication only. Nuclei reported two different matching passwords, which is

										itself suspicious; no login was attempted.
17	**PHP-CGI argument injection (potential)**	HTTP, 80 (PHP 5.2.4)	CVE-2012-1823	High (3): web-reachable, no login	High (3): can allow code execution on the server	**High (9)**	CIS 7.4, 2.2 / PR.IP-12	An attacker could run code on the web server.	Upgrade PHP to a supported version.	UNVERIFIED. Flagged by Nuclei; PHP 5.2.4 is confirmed by phpinfo.php (Fig. 12), but no exploit was attempted.
18	**Apache JServ (AJP) exposed, possible "Ghostcat" (potential)**	AJP, 8009	CVE-2020-1938	Medium (2): port is open, but the match may be wrong	Medium (2): file reads from the web application if it applies	**Medium (4)**	CIS 4.8, 7.4 / PR.PT-3, PR.IP-12	Possible exposure of web application files and settings.	Disable AJP if unused, or restrict it to localhost.	UNVERIFIED, possible false positive. Nmap confirmed AJP is open. Nuclei rated it critical, but the documented affected Tomcat versions start at 7.x and this server runs Tomcat 5.5, so the match is treated with caution.
19	**Samba remote code execution (potential)**	SMB, 445 (Samba 3.0.20)	CVE-2026-4480	Low (1): needs a print command configured, and 3.0.20 is not clearly in the affected range	High (3): remote code execution if it applies	**Medium (3)**	CIS 2.2, 7.4 / PR.IP-12, ID.RA-1	Possible full control of the file server.	Upgrade Samba to a supported release; disable printing features if unused.	UNVERIFIED, version match only. Nuclei flagged it as critical; the version is confirmed as 3.0.20 by Nmap, but applicability was not checked.
20	**HTTP TRACE method enabled**	HTTP, 80	N/A (cross-site tracing; Nikto 000434, Nuclei http-trace)	Medium (2): needs a victim's browser and other conditions	Low (1): can help steal session data in some attacks	**Low (2)**	CIS 4.1, 16.7 / PR.IP-1	A small contribution to web attacks.	Disable TRACE (TraceEnable off).	Reported by two tools. Not tested by hand.
21	**Missing web security headers**	HTTP, 80	N/A (Nikto 013587; Nuclei http-missing-security-headers)	Medium (2): weakens browser protections	Low (1): a hardening gap, not direct access	**Low (2)**	CIS 4.1, 16.7 / PR.IP-1	Raises exposure to browser-side attacks such as clickjacking.	Add headers such as Content-Security-Policy, X-Content-Type-Options and HSTS (HSTS applies once HTTPS is in use).	Reported by two tools. Not tested by hand.

10. Limitations

- The assessment was conducted on 20 October 2026 against one virtual machine. The results reflect what was observed during that assessment and do not represent continuous monitoring.
- Findings marked as unverified were not manually tested or exploited. They remain potential risks until confirmed through controlled testing.
- **Nuclei:** Both scans reported runtime errors in 10 templates. The installed version was also reported as outdated, and ports 9780, 4040 and 5814 were skipped as unresponsive.
- **Nikto:** The update check failed with a 403 error, and 16 errors were recorded during the scan.
- **Port coverage:** The full scan covered TCP ports only. UDP services were identified only where Nuclei probed them, including NetBIOS and RPC.
- **Risk ratings:** The likelihood and impact ratings are my own assessment based on the available evidence. Ratings for unverified findings remain provisional, as indicated in the Status column of the risk table.